

RANSOMWARE INCIDENT REPORT

Orion Health Services

Prepared for: Executive Leadership Team

Prepared by: Security Team - Cybersecurity Analyst (Graduate)

Date of Report: 09 Jul 2026

Classification: Confidential - Internal Use Only

Executive Summary

Orion Health Services has been affected by a ransomware attack. The IT team noticed unusual outbound traffic from one of their internal servers, several employees reported being locked out of systems, and a ransom note appeared on the shared drive.

The initial entry point has been identified by the Security team: a phishing email received by a finance team member, containing a malicious Excel attachment.

The identified impact is that the attacker gained domain-level access through credential harvesting from an employee's compromised workstation, gaining access to file servers including shared drives, PII (Personally Identifiable Information) of employees, PHI (Personal Health Information) of patients, and the company's payroll data.

The current status of the compromise is that the security team has identified the initial entry point, collected information on compromised data, systems affected, and the Indicators of Compromise (IOCs).

Incident Timeline

Below are the details of the events that took place during this attack.

#	Event
1	A phishing email was received on a finance team member's computer, containing an attached malicious Excel file. Execution of the file gave the attacker access to the team member's workstation.
2	The security team identified the use of the Mimikatz application on the workstation by the attacker, used for credential harvesting from system memory.
3	The credential harvest from system memory gave the attacker domain-level access to the systems and infrastructure of the company.
4	The security team identified a login from an overseas IP address using the compromised domain credentials, indicating the attacker was accessing company resources remotely from outside Australia/New Zealand.
5	After accessing the systems, the attacker performed lateral movement across the company infrastructure, including the file server, HR/Finance systems, and partially the backup server.
6	Finally, encrypted files with the .orionlock extension were discovered, along with a ransom note on the shared drive, confirming the final impact stage of the attack.

Note: Mimikatz is a powerful, open-source Windows application created by French security researcher Benjamin Delpy to demonstrate vulnerabilities in Microsoft authentication protocols. It operates as a post-exploitation "hacktool" designed to extract sensitive authentication credentials directly from system memory.

Impact Assessment

Severity: This incident is assessed as Critical/High severity due to the combination of ransomware impact, domain-level compromise, and exposure of financial and health data.

This attack has affected the company in many different ways. The company's data, systems, business operations, and legal compliance are all at risk.

Data Impact

The attack has compromised sensitive data of the company, such as employee payroll records, which include financial and personal data; patient appointment schedules, which are categorised as Personal Health Information (PHI); and internal system credentials, which include usernames and password hashes. All of this information is sensitive, and immediate action to recover and protect this data is required. The company employs approximately 250 staff, all potentially affected by the payroll and credential compromise; the exact number of affected patient records is still being determined.

Systems Impact

This attack resulted in restricted access to the company's system infrastructure. The file server and HR/Finance systems have been compromised and encrypted, with a ransom note confirming this is a ransomware attack. As a result, internal systems are inaccessible. The backup server has also been partially affected, which is a more serious issue, as it leaves a question mark over recovery options.

Business Impact

The business has been impacted by a fair number of disruptions. Business operations are at risk, as the attack has impacted the HR and Finance systems. This means that, if recovery takes longer, it will impact payroll runs, which in turn will affect staff members. Employee work and operations will also be disrupted, as most workstations are locked and inaccessible. This also means that clinics working under Orion won't be able to connect to the cloud infrastructure and access relevant data. This also presents a third-party risk, as affected clinics may face their own breach notification obligations as data controllers for their patients, independent of Orion's direct regulatory obligations. Patient appointment schedules are suspected to have been accessed and potentially exfiltrated, pending forensic confirmation. If confirmed, this will affect client and patient trust in the business.

Financial Impact

This attack will have a financial impact on the company. Potential costs include incident response and forensics, legal counsel, credit monitoring for affected individuals, regulatory fines, potential ransom payment, recovery costs if the ransom is not paid, and reputational costs due to potential loss of business.

Reputational Impact

As healthcare data is considered highly sensitive, this breach is likely to significantly affect the company's reputation. This is likely to result in a loss of trust among clients, patients, and partner organisations.

Regulatory and Legal Impact

As this attack includes a privacy data breach, it also carries regulatory and legal implications. Possible Notifiable Data Breaches (NDB) scheme (AU) and Privacy Act 2020 (NZ) notification obligations have been identified, and preparation of formal breach notification statements should begin promptly.

In summary, this incident presents critical risk across data confidentiality, business continuity, financial standing, and regulatory compliance, requiring an immediate and coordinated response across IT, Legal, and Executive leadership.

Root Cause Analysis

This section outlines the underlying causes that allowed the ransomware attack to succeed and escalate across Orion Health Services' infrastructure. While the initial entry point was a phishing email, the scale of the impact was driven by a combination of technical and procedural gaps across endpoint security, access management, network architecture, and authentication controls. Each contributing factor identified below is directly linked to the recommendations outlined later in this report.

From the analysis of the security team, the initial entry point of the attack has been identified as a malicious attachment received through a phishing email to a finance team workstation. This leaves two questions: first, why the email content filtering was unable to detect or block the malicious attachment, and second, whether the macro was allowed to run automatically. These are considered the primary root causes for the start of the attack.

The attacker then operated within the company's systems, and the contributing factors stem from a lack of endpoint detection. Mimikatz is a well-known tool, and the use of this hacking tool going undetected suggests that the EDR or antivirus on the company's systems was misconfigured or otherwise compromised.

The attacker also used Mimikatz to obtain domain-level credentials. This suggests that an administrator had previously logged into the standard workstation, leaving credentials in memory. This points to a gap in Privileged Access Management (PAM), where privileged accounts were not adequately separated from standard user workstations.

After gaining access, the attacker was able to move laterally across the file server, HR/Finance systems, and the backup server, and all of these systems were reachable from a standard user segment. This points to a lack of network segmentation based on system function or sensitivity.

Another key finding is that the successful login from an overseas IP address using compromised credentials indicates that Multi-Factor Authentication (MFA) was not enforced for remote or administrative access. MFA should be enforced for all access originating outside the corporate network.

The backup server was reachable from a standard workstation, meaning it was not isolated within the network. This represents one of the most serious flaws identified in this investigation.

In summary, this incident was made possible by a combination of factors: a phishing email that bypassed email filtering controls, undetected use of a well-known credential-harvesting tool due to gaps in endpoint detection, insufficient separation of privileged accounts, absence of network segmentation between critical systems, lack of enforced MFA for remote access, and an inadequately isolated backup server. No single failure caused this incident; rather, the combined absence of layered

security controls allowed what began as a single-workstation compromise to escalate into a company-wide ransomware event. These gaps, taken together, form the basis for the recommendations in the following section.

Recommendations

Given the Critical/High severity of this incident and the range of systemic gaps identified in the Root Cause Analysis, the following recommendations are structured by priority and timeframe: immediate, short-term, and long-term. This structure ensures both rapid containment and recovery, as well as long-term prevention of similar incidents.

Immediate Actions

- Complete isolation of the affected systems.
- Enforce a full password reset across all domain accounts, especially privileged and admin accounts.
- Verify the integrity of the backup server before attempting any restoration.
- Engage an external Incident Response and Forensics team to confirm the scope of data exfiltration.
- Notify legal counsel to begin the regulatory breach assessment.

Short-Term Actions

- Reconfigure and deploy Endpoint Detection and Response (EDR) with detection rules specifically set up to catch tools like Mimikatz.
- Enforce Multi-Factor Authentication (MFA) for all remote and administrative access without exception.
- Disable Office macros by default across the organisation, or restrict them to digitally signed macros only.
- Isolate the backup server on a separate, segmented network and move toward immutable/offline backup storage.
- Strengthen email filtering and attachment sandboxing to detect malicious attachments before delivery.

Long-Term Actions

- Implement network segmentation based on function and sensitivity.
- Implement a Privileged Access Management (PAM) solution, ensuring admin credentials are never used on standard workstations.
- Establish a regular phishing simulation and security awareness training program for all staff, especially finance and HR.
- Conduct a full security architecture review, potentially adopting a Zero Trust model given the sensitivity of the healthcare data handled.
- Review and test the Incident Response plan and backup/recovery process regularly.

- Review contracts with clinic clients to clarify breach notification responsibilities in future incidents.

Addressing this incident effectively requires action across all three timeframes. Immediate actions focus on containment, credential security, and regulatory compliance to limit further damage. Short-term actions close the specific technical gaps that allowed this attack to succeed and escalate, particularly around detection, authentication, and backup resilience. Long-term actions represent a broader shift toward a more mature security posture, including network segmentation, privileged access controls, and a Zero Trust approach, that will reduce the likelihood and impact of future incidents. Given the sensitivity of the data involved and Orion's role as a healthcare technology provider, these recommendations should be treated as a priority investment area, with executive sponsorship to ensure timely implementation.